

BEFORE Placeholder

AFTER

Minimum Security Requirements by Tier (Critical / Important / Low)

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Every 12 months or upon material change

1. Purpose

This document defines the minimum security requirements for third parties based on tier classification. Requirements are expressed as **MUST** (non-negotiable unless an approved exception exists) and **SHOULD** (expected where practical; deviations recorded as gaps).

2. Applicability

These requirements apply to suppliers that:

- process/store/transmit organisational data, and/or
- integrate/connect to organisational systems, and/or
- have privileged access, and/or
- support business-critical services.

When a supplier provides multiple services, requirements apply to the highest-risk service scope.

3. General requirements (all tiers)

All suppliers **MUST**:

- Maintain an information security program appropriate to the service provided.
- Provide a named security contact for assurance queries and incident communications.
- Notify the organisation of material security incidents affecting the service scope within agreed timelines.
- Maintain an up-to-date inventory of sub-processors used to deliver the service (where applicable) and notify material changes.
- Support offboarding, including timely removal of access and secure data return/deletion as contractually agreed.

4. Tier requirements

4.1 Critical (Tier 1) — Minimum requirements

Identity & access

Critical suppliers MUST:

- Enforce MFA for all administrative access.
- Support SSO (SAML/OIDC) for user authentication where the service supports it; local accounts for standard users are not permitted unless justified and approved.
- Implement least privilege via role-based access controls for customer environments/tenants.
- Support time-bound access for privileged support activities (or equivalent controls) with auditable approvals.

Critical suppliers SHOULD:

- Provide privileged session logging (or equivalent audit trail) for interactive admin support.
- Support SCIM (or equivalent) for automated provisioning/deprovisioning where practical.

Connectivity & integration

Critical suppliers MUST:

- Use approved integration patterns for connectivity, including restricted scope, least-privilege APIs, and explicit network rules.

- Prohibit inbound connectivity into organisational environments unless explicitly approved and risk assessed.
- Maintain secure key/certificate management for integrations (e.g., rotation, secure storage).

Critical suppliers SHOULD:

- Support mutual authentication (mTLS) for API integrations where practical.
- Provide IP allowlisting capabilities for admin interfaces and API endpoints where applicable.

Logging, monitoring & auditability

Critical suppliers MUST:

- Provide audit logs for administrative actions and authentication events relevant to the service scope.
- Provide an agreed log retention period for auditability, and the ability to export logs on request (or provide access to retrieve them).
- Provide evidence of active monitoring for security-relevant events proportionate to service criticality.

Critical suppliers SHOULD:

- Provide customer-accessible audit log retrieval and alerting where the service supports it.
- Provide a defined process for responding to security log requests during incidents.

Vulnerability management & secure delivery

Critical suppliers MUST:

- Maintain a documented vulnerability management process, including scanning/assessment cadence.
- Remediate critical/high vulnerabilities within defined timelines appropriate to risk (or provide mitigations and a plan).
- Provide independent security testing evidence (e.g., penetration test executive summary) within the last 12 months where applicable to the service.

Critical suppliers SHOULD:

- Provide a summary of security testing coverage (SAST/DAST/dependency scanning) for software/SaaS services.

Data protection & privacy

Critical suppliers **MUST**:

- Encrypt data in transit and at rest for the service scope.
- Disclose data residency and processing locations for in-scope data.
- Support secure deletion and/or data return on offboarding, with confirmation on request.
- Provide contractually agreed privacy terms for personal data processing (where applicable).

Critical suppliers **SHOULD**:

- Provide key management approach details (high-level) and rotation practices.

Incident response & notification

Critical suppliers **MUST**:

- Maintain a documented incident response process and provide notification commitments for material incidents.
- Support timely information sharing during incidents (scope, impact, containment actions, and remediation plan).

Critical suppliers **SHOULD**:

- Provide evidence of incident response testing (e.g., tabletop/exercise summary) within the last 12–18 months.

Resilience & recovery

Critical suppliers **MUST**:

- Provide a resilience approach appropriate to criticality (redundancy, backups, restore capability).
- Provide RTO/RPO capabilities or service restoration expectations where applicable.
- Provide evidence of periodic recovery testing (summary acceptable).

Critical suppliers **SHOULD**:

- Support customer-defined resilience requirements where contractually agreed.

Sub-processors (fourth parties)

Critical suppliers MUST:

- Provide a sub-processor list relevant to service delivery.
- Maintain a process to assess sub-processors and manage security obligations down the chain.
- Notify material sub-processor changes affecting the service.

Critical suppliers SHOULD:

- Support sub-processor due diligence for material components on request.
-

4.2 Important (Tier 2) — Minimum requirements

Important suppliers MUST:

- Enforce MFA for administrative access.
- Provide a named security contact and incident notification commitments.
- Support least privilege roles and limit administrative access.
- Provide a documented vulnerability management and patching process.
- Provide basic audit logging for admin/auth events where the service supports it.
- Provide data protection commitments appropriate to in-scope data types and residency.

Important suppliers SHOULD:

- Support SSO for standard user access where the service supports it.
 - Provide independent security testing evidence (summary acceptable) where applicable.
 - Provide a documented backup/restore approach (if the supplier hosts in-scope data).
-

4.3 Low (Tier 3) — Minimum requirements

Low suppliers **MUST**:

- Provide basic assurance information proportionate to the service scope.
- Use MFA for administrative access where the service supports it.
- Provide incident notification contact details for material security events.
- Confirm data handling and offboarding approach if any organisational data is processed.

Low suppliers **SHOULD**:

- Support SSO where practical.
- Provide basic audit logging where available.

5. Exceptions and compensating controls

Any deviation from a **MUST** requirement requires an approved exception, including:

- Defined compensating controls (technical preferred)
- Residual risk acceptance by the appropriate authority
- Remediation plan and expiry date
- Re-validation checkpoint

See: ``program-charter/04-policy-exceptions-standard.md``

6. Mapping and supporting artifacts

Supporting artifacts referenced by this standard:

- Tiering decision tree and intake template: ``tiering-model/``
- Evidence request packs by tier: ``evidence-packs/``
- Control baselines and validation steps: ``control-baselines/``
- Secure integration patterns: ``integration-patterns/``
- Ongoing monitoring triggers and cadence: ``monitoring/``